

Manual 23 — Implementação Controlada do DORA

Tradução de projeto pt-BR — não oficial

****Ordem da série:**** 23

****Base estatutária principal:**** Regulamento (UE) 2022/2554 (DORA)

****Regra de camadas de fontes:**** texto estatutário, atos delegados/de execução, materiais de supervisão, prática contratual e procedimentos internos permanecem distintos.

****Limite:**** Este manual não substitui GDPR, NIS2, requisitos prudenciais setoriais, legislação nacional ou instruções de autoridades competentes.

01. Governança e responsabilização

Estabeleça uma estrutura de resiliência operacional digital aprovada pelo órgão de administração, com responsabilidades nomeadas, direitos de decisão, frequência de reporte, limiares de escalonamento e retenção de evidências. Registre responsáveis, delegações, decisões materiais, questionamentos e acompanhamento da remediação.

02. Escopo e aplicabilidade

Determine quais entidades jurídicas, serviços, filiais, ativos de TIC e acordos de terceirização estão sujeitos ao DORA. Vincule conclusões de escopo aos fatos de entidade e serviço; não generalize a aplicabilidade além da evidência disponível.

03. Estrutura de gestão de riscos de TIC

Mantenha uma estrutura documentada de gestão de riscos de TIC integrada à gestão de riscos corporativos. Defina objetivos, domínios de controle, apetite/tolerância, tratamento de exceções, testes e gatilhos de reavaliação.

04. Mapeamento de ativos e dependências

Mantenha inventários atuais de ativos de informação e TIC, sistemas, aplicações, fluxos de dados, funções críticas, dependências, interfaces e serviços de terceiros. Relacione dependências de serviços de negócio a componentes técnicos e responsáveis.

05. Proteção e prevenção

Implemente salvaguardas preventivas proporcionais ao risco, incluindo controle de acesso, configuração segura, gestão de mudanças, proteção de rede, criptografia, defesas contra malware, gestão de vulnerabilidades, desenvolvimento seguro e controles físicos/ambientais quando aplicável.

06. Detecção

Defina capacidades de monitoramento e detecção para atividade anômala, degradação de serviço, falhas de integridade, acesso não autorizado, falhas de controle e interrupções de terceiros. Preserve lógica de alertas, propriedade, critérios de triagem e evidências.

07. Resposta

Mantenha procedimentos documentados de resposta a incidentes de TIC cobrindo classificação, comando, comunicação, contenção, investigação, coordenação de recuperação, preservação de evidências, registro de decisões e roteamento de notificações regulatórias.

08. Recuperação e restauração

Defina prioridades de recuperação, objetivos, procedimentos de restauração, processamento alternativo, sequenciamento de dependências, verificações de integridade e validação do negócio antes do retorno à operação normal.

09. Controles de backup e restauração

Use arranjos resilientes de backup com escopo, frequência, retenção, segregação, imutabilidade ou proteção equivalente quando apropriado, testes de restauração e evidências de que os objetivos de recuperação permanecem alcançáveis.

10. Aprendizado e melhoria

Realize revisões estruturadas pós-incidente e pós-teste. Registre causas raiz, lacunas de controle, lições aprendidas, ações corretivas, responsáveis, prazos, evidências de verificação e gatilhos de reavaliação.

11. Comunicação

Mantenha procedimentos de comunicação interna e externa para grandes interrupções de TIC. Defina partes interessadas, aprovação de mensagens, escalonamento, considerações de mídia/mercado/clientes e responsabilidades de contato regulatório.

12. Classificação de incidentes de TIC

Use critérios documentados para classificar incidentes relacionados a TIC. Mantenha modelos internos de severidade separados dos critérios regulatórios e revalide limiares e normas técnicas aplicáveis antes da publicação e do uso.

13. Reporte de incidentes graves

Mantenha um processo fail-closed para determinar se um incidente de TIC atende aos requisitos de reporte de incidente grave. Registre autoridade competente, campos exigidos, etapas, prazos, evidências e correções. Revalide modelos e regras de prazo atuais antes do uso operacional.

14. Notificação voluntária de ameaças cibernéticas

Mantenha a notificação voluntária de ameaças cibernéticas significativas separada do reporte obrigatório de incidentes graves. Documente autoridade decisória, justificativa, destinatários e quaisquer obrigações resultantes.

15. Estratégia de testes

Mantenha um programa de testes de resiliência operacional digital baseado em risco para sistemas e serviços de TIC que suportem funções críticas ou importantes. Defina escopo, frequência, independência, evidências, remediação e reteste.

16. Avaliações de vulnerabilidade

Realize avaliações de vulnerabilidade com métodos proporcionais à criticidade e exposição. Registre achados, severidade, controles compensatórios, prazos, exceções, evidências e verificação de encerramento.

17. Testes de cenário e resiliência

Use testes baseados em cenários para validar a resiliência frente a interrupções severas plausíveis. Inclua pessoas, processos, tecnologia, instalações, comunicações, dependências de terceiros e decisões de recuperação.

18. Testes de penetração orientados por ameaças

Quando aplicável, gerencie TLPT como um regime de controle distinto. Verifique aplicabilidade da entidade, escopo, requisitos dos testadores, expectativas da autoridade, evidências, remediação e obrigações de reteste antes da execução.

19. Independência e competência dos testadores

Defina requisitos de independência, competência, conflito de interesses, confidencialidade, autorização e evidências para testadores internos e externos. Mantenha requisitos regulatórios formais distintos das expectativas internas de qualidade.

20. Remediação e reteste

Gerencie achados por um ciclo controlado de remediação com responsável, classificação de risco, data-alvo, autoridade de exceção, evidência de encerramento e reteste quando necessário.

21. Estrutura de risco de terceiros de TIC

Mantenha governança para riscos de terceiros de TIC em onboarding, due diligence, contratação, monitoramento, incidentes, concentração, mudanças, renovação, saída e retenção de evidências.

22. Due diligence pré-contratual

Antes de contratar serviços de TIC, avalie capacidade do fornecedor, segurança, resiliência, tratamento de dados, adequação legal/regulatória, subcontratação, dependências geográficas, auditabilidade, continuidade, viabilidade de saída e concentração.

23. Controles contratuais

Use disposições contratuais apropriadas à criticidade do serviço e aos requisitos DORA aplicáveis. Cubra descrição do serviço, localizações, segurança, apoio a incidentes, direitos de acesso/auditoria, continuidade, devolução de dados, término, cooperação e acesso regulatório quando aplicável.

24. Subcontratação e risco da cadeia

Identifique cadeias materiais de subcontratação, dependências críticas, localizações, risco de substituição, concentração, notificação de mudanças e obrigações a jusante. Não trate a supervisão do fornecedor principal como eliminação do risco da cadeia.

25. Risco de concentração

Avalie concentração entre fornecedores, serviços, tecnologias, regiões geográficas, localizações de dados, infraestrutura comum e substituíbilidade. Documente premissas, cenários de estresse, mitigações e decisões de gestão.

26. Registro de informações

Mantenha o registro de informações exigido para acordos de TIC relevantes usando estrutura e campos prescritos atuais. Revalide modelos, taxonomia, expectativas de apresentação e instruções da autoridade competente antes do envio.

27. Provedores terceiros críticos de TIC

Mantenha controles para dependências de provedores designados ou potencialmente sujeitos ao marco de supervisão da UE para provedores terceiros críticos de TIC. Distinga a supervisão do provedor das responsabilidades contínuas de cada entidade financeira.

28. Planejamento de saída e transição

Crie planos testados de saída e transição para serviços de TIC que suportem funções críticas ou importantes. Aborde portabilidade de dados, provedores alternativos, viabilidade de internalização, sequenciamento, continuidade, transferência de conhecimento, gatilhos contratuais e risco residual.

29. Métricas de resiliência operacional

Defina métricas e indicadores para incidentes, recuperação, testes, desempenho de terceiros, vulnerabilidades, remediação, exceções, concentração e eficácia de controles. Vincule métricas a decisões e escalonamento.

30. Evidências e prontidão supervisora

Mantenha objetos de evidência para cada controle material, incluindo política, responsável, procedimento, registro operacional, resultado de teste, exceção, remediação, aprovação quando necessária e reavaliação. Garanta suporte a auditoria interna, asseguração externa e solicitações de autoridades.

31. Localização e controle de implementação

Traduza somente a partir de uma fonte inglesa exata congelada. Preserve termos legais e regulatórios, distinções de reporte de incidentes, terminologia de terceiros, limites de escopo e status de tradução não oficial. Execute verificações de paridade estrutural e semântica antes da geração de candidatos.

32. Monitoramento de fontes, mudanças, proveniência e publicação

Antes do congelamento e publicação do candidato, revalide a aplicabilidade do Regulamento (UE) 2022/2554, atos delegados/de execução, materiais das ESAs, normas técnicas de reporte de incidentes, requisitos de TLPT, especificações do registro de informações e atualizações de supervisão. Vincule commit-fonte, fontes localizadas, binários DOCX/PDF, identidades SHA-256, QA de renderização/acessibilidade, resultados de segurança de workflows, estado de publicação do predecessor e reconciliação do registro.

Se não houver defeito material não resolvido e todos os gates objetivos aplicáveis estiverem verdes, publique sob a autorização permanente do repositório.

Registro mínimo de controle para cada capítulo

Para cada capítulo substantivo, os registros de implementação devem identificar: camada de fonte aplicável; decisão de aplicabilidade; responsável; procedimento operacional; objeto/localização de evidência; método de revisão ou teste; caminho de exceção/remediação; e gatilho de reavaliação.